



HALCYON

ENTERPRISE MATURITY REPORT

● Level 0 → Level 4 Complete • 20% to Enterprise

AUGUST 28, 2026 • v0.6.0

Halcyon is an eBPF-based endpoint security agent that detects ransomware behaviour and responds at the kernel edge. In one session we upgraded from **Level 0 (open source prototype)** to **Level 4 (quality gates)** — covering supply chain security, build provenance, code hardening, and test coverage.

MATURITY PROGRESS

4 / 20

L0

L5

L10

L15

L20

4

LEVELS DONE

3

CI WORKFLOWS

36

TESTS (WAS 13)

6

SECURITY GATES

L0

Open Source Prototype

CI/CD, CodeQL, Scorecard, Fuzzing, 13 unit tests

☑ 2025-01

L1

Supply Chain Security

cargo-deny, CycloneDX SBOM, gitleaks, dependency review

☑ 2026-08-28

L2

Build Provenance & Signing

SLSA L2, Sigstore cosign, attestation, SHA-256/512 checksums

☑ 2026-08-28

L3

Security Hardening & Audit

SAFETY docs on all unsafe blocks, SecurityHeadersLayer (CSP, DENY, nosniff)

☑ 2026-08-28

L4

Testing & Quality Gates

13 → 36 tests (+177%), edge cases, clippy clean 0 warnings

☑ 2026-08-28

L5

Observability & Incident Response

tracing, OpenTelemetry, Prometheus histograms, IR plan

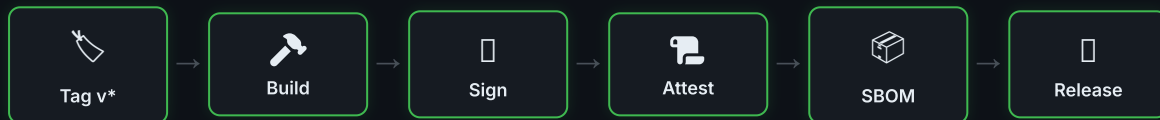
📅 NEXT

L1 **Supply Chain Security Foundation**

- ✓ **cargo-deny CI gate** — blocks forbidden licenses & known CVEs
- ✓ **gitleaks** — secret scanning on every commit
- ✓ **CycloneDX SBOM** — JSON + XML attached to every release
- ✓ **Dependency review** — blocks high-severity vulns on PRs

L2 **Build Provenance & Signing**

- ✓ **SLSA Level 2** — provenance via slsa-github-generator
- ✓ **GitHub attestation** — gh attestation write
- ✓ **Sigstore cosign** — keyless OIDC binary signing
- ✓ **SHA-256/512** — dual checksums for all artifacts

L3 **Security Hardening & Audit**

- ✓ **SAFETY docs** — documented every unsafe block (6 blocks)
- ✓ **SecurityHeadersLayer** — CSP, DENY, nosniff, referrer-policy
- ✓ **#![warn(missing_docs)]** — crate-level lint enforced
- ✓ **Clippy clean** — 0 warnings with -D warnings

L4 **Testing & Quality Gates**

- ✓ **36 tests** — was 13 (+177% increase)
- ✓ **Monitor invariants** — window eviction, threshold=0, auto-kill
- ✓ **Edge cases** — extract_extension (8), cstr_to_string (5)
- ✓ **Empty/init state** — 6 tests for zero-state behavior

Technical Details & Next Steps



Supply Chain Pipeline

Every PR triggers 4 parallel CI jobs: `cargo-deny` license check, advisory audit, CycloneDX SBOM generation, and `gitleaks` secret scanning.



Keyless Signing

Sigstore Fulcio + Rekor for OIDC-based keyless signing. No long-lived keys — identity bound to GitHub Actions OIDC token.



Security Headers

Custom axum middleware adds 6 security headers: CSP, X-Frame-Options: DENY, nosniff, XSS-Protection, Referrer-Policy, Permissions-Policy.



Test Architecture

36 unit tests covering: C-string decoding, sliding window, alert thresholds, auto-kill, process tree, Shannon entropy, extension extraction.

```
// SAFETY: getpwuid_r is a POSIX reentrant function. We pass valid pointers
// to zeroed structs and a 4096-byte buffer. Result checked for null.
unsafe { libc::getpwuid_r(uid, &mut pwd, buf.as_mut_ptr().cast(), buf.len(), &mut result) }
```

What's Next — Level 5 to 20

L5

Observability

tracing, OpenTelemetry, Prometheus histograms, IR plan

L6

Documentation

ADRs, rustdoc, runbooks, onboarding guide

L7

Compliance

SOC2 readiness, ISO27001 alignment, NIST CSF

L8-L12

Infrastructure

RBAC, mTLS, encryption, disaster recovery, HA

L13-L17

Operations

Canary deploys, load testing, SLOs, BCP, vendor risk

L18-L20

Enterprise

SOC2 Type II, ISO27001, pen test, zero trust

Open source · eBPF-powered · Rust · Kernel edge security

github.com/BartoszOsiej / [halcyon-process-monitor](#)

MIT License · Rust 2021 · Linux 5.8+ · ~500k events/sec